

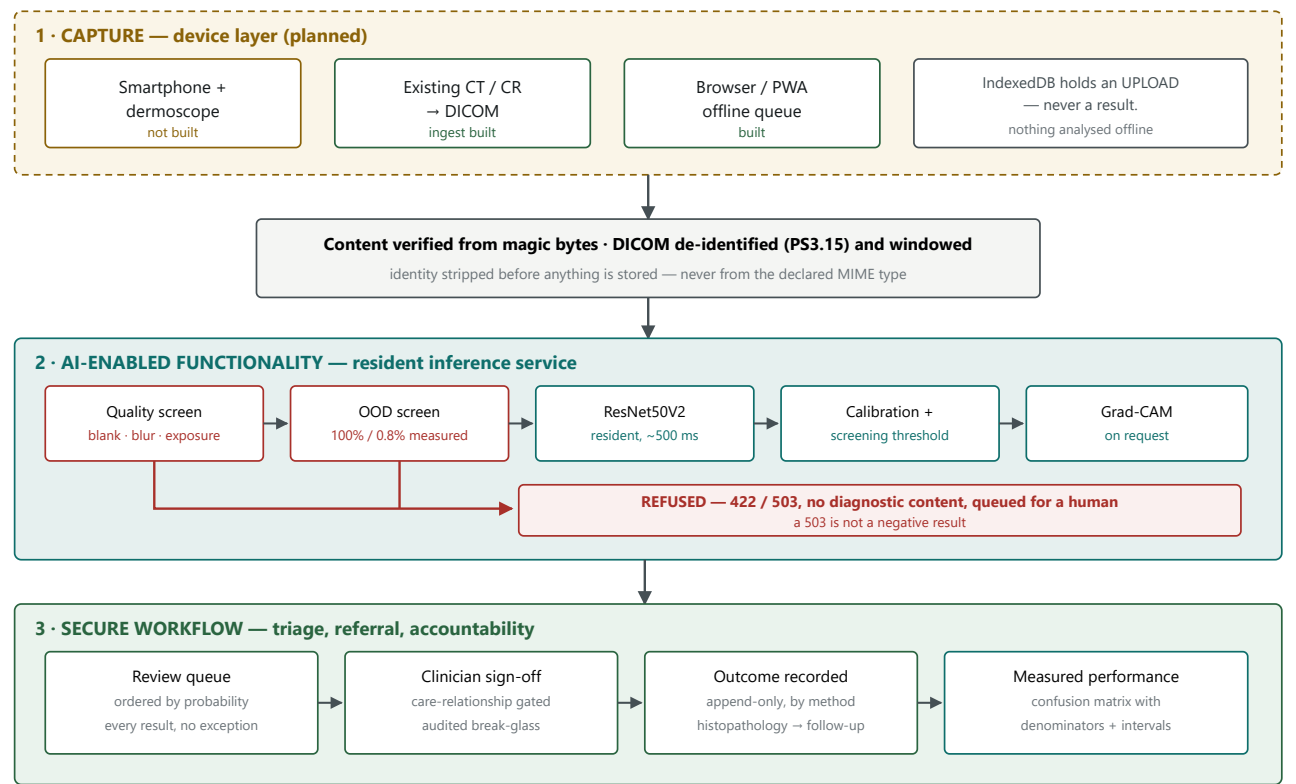
Architecture

HealthAI Assistant · mapped to Pre-Application Guidelines §2's three required components · Category A (TRL 4), Track 2

§2 component coverage

COMPONENT	STATUS	EVIDENCE
Hardware / device capability	Planned	Not built. Costed integration plan with named candidate hardware and a DICOM path from installed radiology equipment — docs/DEVICE_INTEGRATION.md . §3 permits Category A applicants to demonstrate this through architecture and development plans.
AI-enabled functionality and decision support	Implemented	Two evaluated classifiers with measured calibration, out-of-distribution screening, and a screening operating point chosen on clinical grounds. Held-out figures reproducible from published commands.
Secure workflow integration (triage, referral)	Implemented	Role-scoped review queue with mandatory sign-off, care-relationship access control with audited break-glass, append-only audit trail, POPIA §72 consent for cross-border processing, outcome recording that makes production performance measurable.

System overview



Red paths are refusals. Three of the five decision points in the AI layer can decline to produce a result.

The feedback loop is the part most systems lack. Confirmed outcomes are recorded against the prediction that was made, so this deployment can compute its own performance rather than quoting the vendor's held-out figure. That is what a procurement decision and a SAHPRA post-market surveillance plan both require, and it was built before there was anything to measure.

Refusal paths, measured

Every path below is a case where the system declines rather than answers. Each is measured, not asserted, and each measurement is reproducible.

CONDITION	RESPONSE	MEASUREMENT
No validated model for the modality	503, no content, queued	Breast, colon, prostate — registry gated on measured balanced accuracy
Image outside training distribution	422, reason given	Wrong modality 100%, in-distribution 0.8%
Blank, blurred, over-exposed	422, reason given	Pixel variance, level, Laplacian — catches what the feature detector scores as in-distribution
Clinical DICOM to the lung model	422, explicit reason	All windows 20.3–30.4 vs 16.51 threshold
Inference service saturated	503 + Retry-After, queued	Bounded queue depth 16
Polygenic score that does not transfer	No percentile at all	Martin et al. 2019 transferability
Partially translated language	Language not offered	Safety-critical key gate + human sign-off
Offline	Upload queued; no result shown	IndexedDB holds an upload only

Security and data protection

CONTROL	IMPLEMENTATION
Encryption at rest	AES-GCM under a rotatable keyring; key ids in the ciphertext envelope so rotation is possible without data loss. Clinical free text, contact details, MFA secrets.
Access control	Care relationships derived from appointments and scan assignments; time-boxed break-glass with written justification, high-severity audit and administrator notification.
Second factor	TOTP with single-use recovery codes; secret encrypted at rest.
Audit	Append-only, non-identifying detail, 34 audited operations; separate genomic access log.
Cross-border (POPIA §72)	Redacted before transmission, consent checked per message, versioned disclosure, transfer log recording categories not values.
Data subject rights	Erasure adjudicated per category against the six-year health-record retention duty; the outcome names the instrument.

Two controls ship in shadow mode. `MFA_ENFORCE` and `CARE_RELATIONSHIP_ENFORCE` both default off, so existing clinicians are not locked out mid-deploy. The care check still runs and records what it *would* have refused, so the derivation can be measured before it starts denying access. **Code that can enforce a control is not the same as a control being enforced**, and the DPIA marks both as mitigated-in-shadow rather than closed.

Deployment

SERVICE	NOTES
Web (Node/Express)	Refuses to start in production without a session secret, TLS, and durable object storage for scan images.
Inference (FastAPI, private)	Both models resident. Private service: nothing outside the cluster submits an image, and it has no authentication of its own by design — it is reached only by the web service, which has already authorised the request and checked consent.
PostgreSQL	Sessions, clinical records, audit. Bounded connection pool sized to the pooler's own limit.
Object storage	Private; reads only via an authorised, audited endpoint issuing 10-minute signed URLs.

Known blocking limitation. The lung model refuses clinical DICOM. The pipeline around it — ingest, de-identify, window, screen, classify, review — is complete and tested; the model at the end of it was trained on web-sourced images and declines every real acquisition. Retraining on a documented CT dataset with patient-level splits is the first item of clinical work, not a later refinement. Recorded in the model card rather than left to be discovered.